

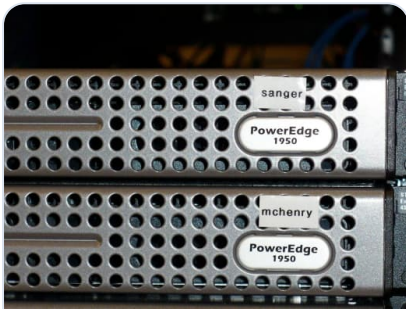
SÉCURITÉ DES APPLICATIONS WEB

Guide de méthode

Projet final · Auditer l'application de réservation



MATÉRIEL QUE TU CROISES DANS CE LABORATOIRE



Serveur

Fournit fichiers, messagerie ou site web aux autres



Pare-feu (firewall)

Filtre le trafic entre deux zones selon des règles



Ordinateur portable

L'ordinateur que l'on emporte partout

Photos issues de Wikimedia Commons : Serveur, Florence Devouard, CC BY-SA 4.0 · Pare-feu (firewall), Jakez, CC BY-SA 3.0 · Ordinateur portable, Ahunt, CC0.

À RETENIR

- ◆ Cadre et limites : tu analyses uniquement des fichiers fournis ; ne teste jamais un système réel sans autorisation écrite. Les exemples de ce guide utilisent des valeurs inventées, pas celles du laboratoire.

1 Qualifier un constat

Relis d'abord la lettre de mission, puis la grille. Quand un constat vient d'un scanner, cherche toujours une preuve qui le confirme ou le contredit dans un autre fichier. Quand un constat vient d'une revue de code, pointe la ligne et nomme le risque sans extrapoler.

◆ Exemple bash

BASH

```
cat > constats-exemple.csv <<'EOF'
id;source;certitude;actif
X01;revue;démontrée;api-resa
X02;scanner;scanner;api-resa
X03;journal+revue;confirmée;front-web
EOF
grep '^X' constats-exemple.csv | cut -d';' -f1,2,3
```

◆ Exemple PowerShell

```
@'
id;source;certitude;actif
X01;revue;démontrée;api-resa
X02;scanner;scanner;api-resa
X03;journal+revue;confirmée;front-web
'@ | Set-Content -Encoding UTF8 constats-exemple.csv
Import-Csv -Delimiter ';' -Encoding UTF8 constats-exemple.csv | Select-Object id, source, certitude
```

2 Recalculer une note CVSS 3.1

Travaille avec la table de la grille. Copie le vecteur, reporte chaque valeur, calcule ISS, impact, exploitabilité, puis applique l'arrondi supérieur. Quand tu annonces une note, garde aussi le vecteur comme justification.

```
cat > vecteur-exemple.txt <<'EOF'
CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:U/C:L/I:L/A:N
EOF
grep 'CVSS:3.1' vecteur-exemple.txt
```

```
@'
CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:U/C:L/I:L/A:N
'@ | Set-Content -Encoding UTF8 vecteur-exemple.txt
Get-Content -Encoding UTF8 vecteur-exemple.txt
```

3 Prioriser sans inventer

La priorité n'est pas un sentiment. Relève la note de base, la criticité de l'actif et la certitude, puis multiplie. Si deux constats semblent proches, vérifie d'abord qu'ils parlent bien du même actif et du même niveau de preuve.

```
cat > priorite-exemple.csv <<'EOF'
id;note;criticite;certitude
X01;6.3;4;3
X02;5.2;2;1
EOF
awk -F';' 'NR>1 { printf "%s %.1f\n", $1, $2*$3*$4 }' priorite-exemple.csv
```

POWERSHELL

```
@'
id;note;criticite;certitude
X01;6.3;4;3
X02;5.2;2;1
"@ | Set-Content -Encoding UTF8 priorite-exemple.csv
Import-Csv -Delimiter ';' -Encoding UTF8 priorite-exemple.csv | ForEach-Object { "{0} {1}" -f $_.id, ([double]$_note *
[int]$_criticite * [int]$_certitude) }
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.

4 Rester factuel dans le rapport

Un résumé de direction dit ce qui est prouvé, l'impact probable et la priorité de correction. Il n'annonce ni compromission générale ni exfiltration sans preuve explicite. Une recommandation vaut mieux qu'un slogan si elle est testable et rattachée à une ligne de code, un en-tête ou un composant.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite. Pour copier les commandes sans coupure de ligne, ouvre la [version texte](#).